

Equifax 2017 Data Breach

A Case Study in Cascading Control Failures

On 7 September 2017, Equifax disclosed one of the most consequential data breaches in history — 147 million people's financial profiles exposed over 76 days. This case study dissects the six interlocking failures that made it possible, and maps each to the vulnerability management principles that could have stopped it.

CASE STUDY

LESSON 8 | VULNERABILITY MANAGEMENT



Who Is Equifax?

Scale & Reach

One of three major US consumer credit reporting agencies. Holds detailed financial profiles on **virtually every American adult**, plus large portions of the UK, Canadian, and other markets. Australian operations added via the acquisition of Veda in 2016.

Why This Target Mattered

The depth and breadth of Equifax's data holdings made it extraordinarily attractive. Names, Social Security numbers, dates of birth, addresses, and credit histories — everything needed for identity fraud at industrial scale. The breach scope ultimately covered **147 million individuals** across multiple countries.

 Australian Veda infrastructure ran separately and was **not** in scope — but regulators at OAIC and ASIC issued formal monitoring statements and later referenced Equifax in patch management guidance.

The Breach at a Glance

147M

People Affected

Personal financial records exposed across the US, UK, and Canada

76

Days Undetected

Attackers operated freely from 13 May to 29 July 2017

51

Databases Accessed

Lateral movement across internal data environment post-exploitation

\$1.7B

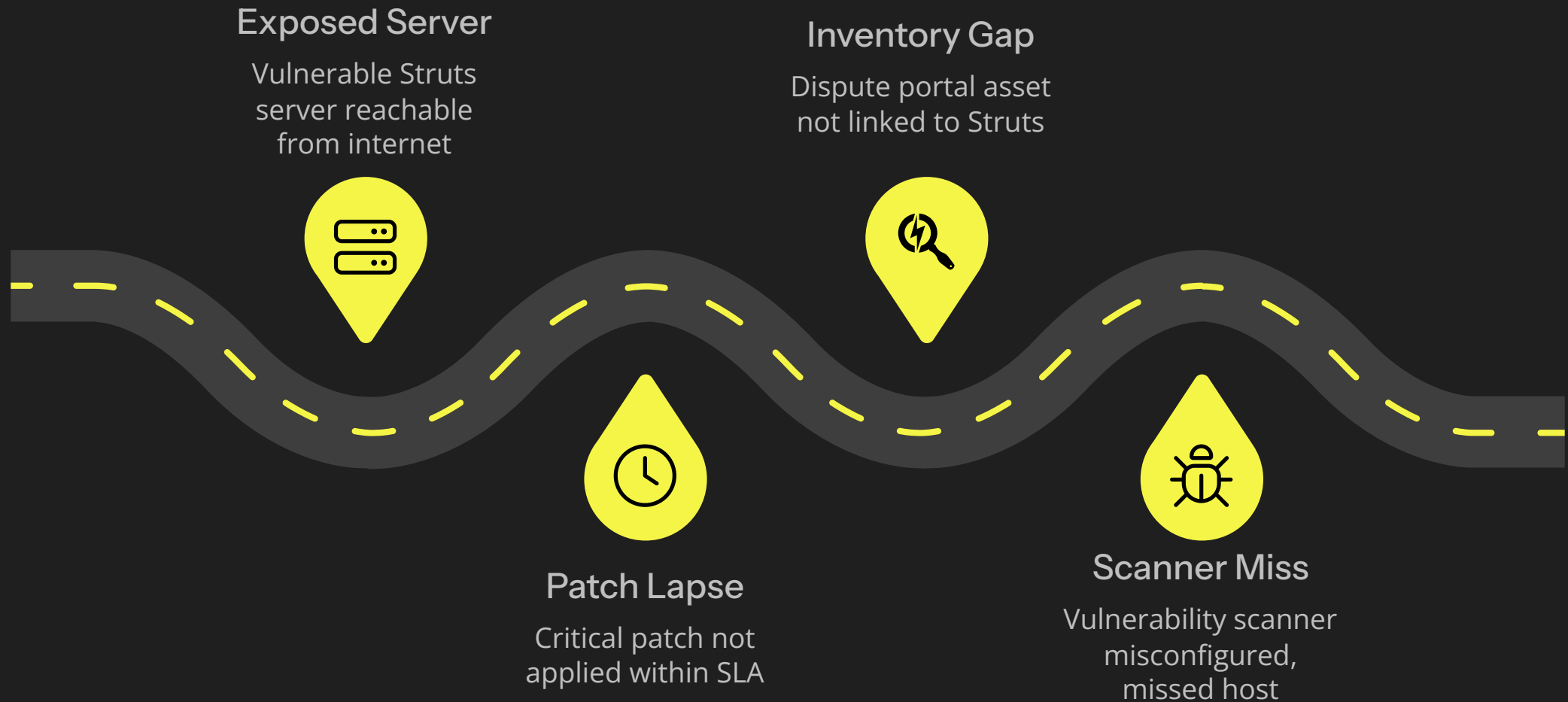
Total Estimated Cost

Remediation, legal settlements, regulatory fines, reputational damage

Six distinct control failures combined to produce this outcome. None in isolation was inevitable — each represented a point where the right operational discipline would have broken the chain.

The Technical Chain of Failure

The breach was not the result of a novel attack or sophisticated zero-day. It was the product of six compounding operational failures across patch management, asset inventory, scanning, and detection.



Each failure was individually preventable. Together, they created an unbroken path from public CVE disclosure to 76 days of undetected exfiltration — a textbook illustration of why vulnerability management is a **workflow**, not a set of tools.

Failure 1 & 2: The Unpatched Vulnerability

CVE-2017-5638

The dispute resolution portal ran Apache Struts 2 on a public internet-facing host. CVE-2017-5638 — a **remote code execution vulnerability with CVSS 10.0** — was publicly disclosed and patched on **6 March 2017**. Patches were immediately available from the Apache project.

- ⊗ This was **not** a zero-day. Equifax had a 67-day window between patch availability and exploitation. The vulnerability was known, well-publicised, and trivially patchable.

The Patch That Never Landed

Equifax received formal CVE notification on **8 March 2017**. Internal policy required patching within **48 hours**. The email was sent to system administrators. The patch was never applied to the dispute portal. Root cause: the patching team had **no visibility** that the dispute portal was running the vulnerable Struts version. Without an accurate asset inventory, the instruction was unactionable.

Failure 3: The Asset Inventory Gap

Equifax did not maintain a comprehensive inventory of which servers ran which software versions. This single gap nullified every other control downstream.

No Software Bill of Materials

The dispute portal's dependency on Apache Struts 2 was not recorded in any accessible asset register. An SBOM-style inventory of application dependencies would have made the connection from *"Critical CVE in Struts"* to *"we use Struts in the dispute portal"* immediate and automatic.

Discovery Only in Retrospect

The dispute portal was only identified as a Struts host when investigators traced the breach back to it — **months after exploitation began**. The internal link between the CVE notification and the vulnerable host was **never made** during the breach window.

Lesson 7 as a Prerequisite

Asset management is the **foundation** of every Lesson 8 control. Without knowing what you have, no vulnerability management programme — however well-designed on paper — can function operationally. Equifax is the canonical proof of that dependency.

Failure 4 & 5: The Scanner Miss and Exploitation

A False Negative at the Worst Moment

An internal vulnerability scan was run on **15 March 2017** — the week after the CVE alert. The scan was configured against the **wrong subnet** and missed the dispute portal entirely. This was a classic false negative: the tooling reported clean, but the coverage was incomplete. Critically, **nobody validated scan coverage**. The dispute portal remained undetected by Equifax's own tooling for the entire breach window.

⚠ Threat feed alerts about CVE-2017-5638 existed and were received. They were never correlated against the asset inventory. Multiple identification layers each failed independently.

Exploitation: 13 May 2017

Two months after patch availability, attackers exploited the Struts vulnerability and gained **remote code execution** on the dispute portal. Initial access was followed by systematic reconnaissance and lateral movement. Over the next **76 days**, the attackers accessed **51 internal databases**, staging data carefully and exfiltrating in encrypted chunks — operating with patience that should have triggered multiple detection controls, none of which fired.

Failure 6: 76 Days Without Detection

The Expired Certificate

Equifax's network inspection appliance had an **expired SSL certificate**. As a result, the tool could not inspect encrypted traffic — and the exfiltration ran encrypted and invisible for the full 76-day window. Detection was triggered only when the certificate was renewed and the tool began seeing outbound encrypted traffic for the first time.

Detection Gaps Throughout

Beyond the certificate failure: no **behavioural alerting** on large outbound transfers from a single host; no **network anomaly detection** on new outbound destinations; no **DLP** flagging sensitive data leaving the environment; no **database access monitoring** on bulk query results.

Attacker Patience

The attackers staged data, exfiltrated in chunks, used encrypted channels, and operated methodically across 51 databases over 11 weeks. This level of dwell time, with this volume of data movement, **would have been detectable** with a layered detection stack in place.

Aftermath & Financial Consequences

Disclosure and Leadership Fallout

Equifax disclosed publicly on **7 September 2017** — six weeks after internal detection on 29 July. The market reaction was swift and severe. Within weeks, the **CEO, CIO, and CSO all resigned**. Congressional hearings followed, as did class-action litigation and multi-jurisdictional regulatory investigations.

The Financial Reckoning

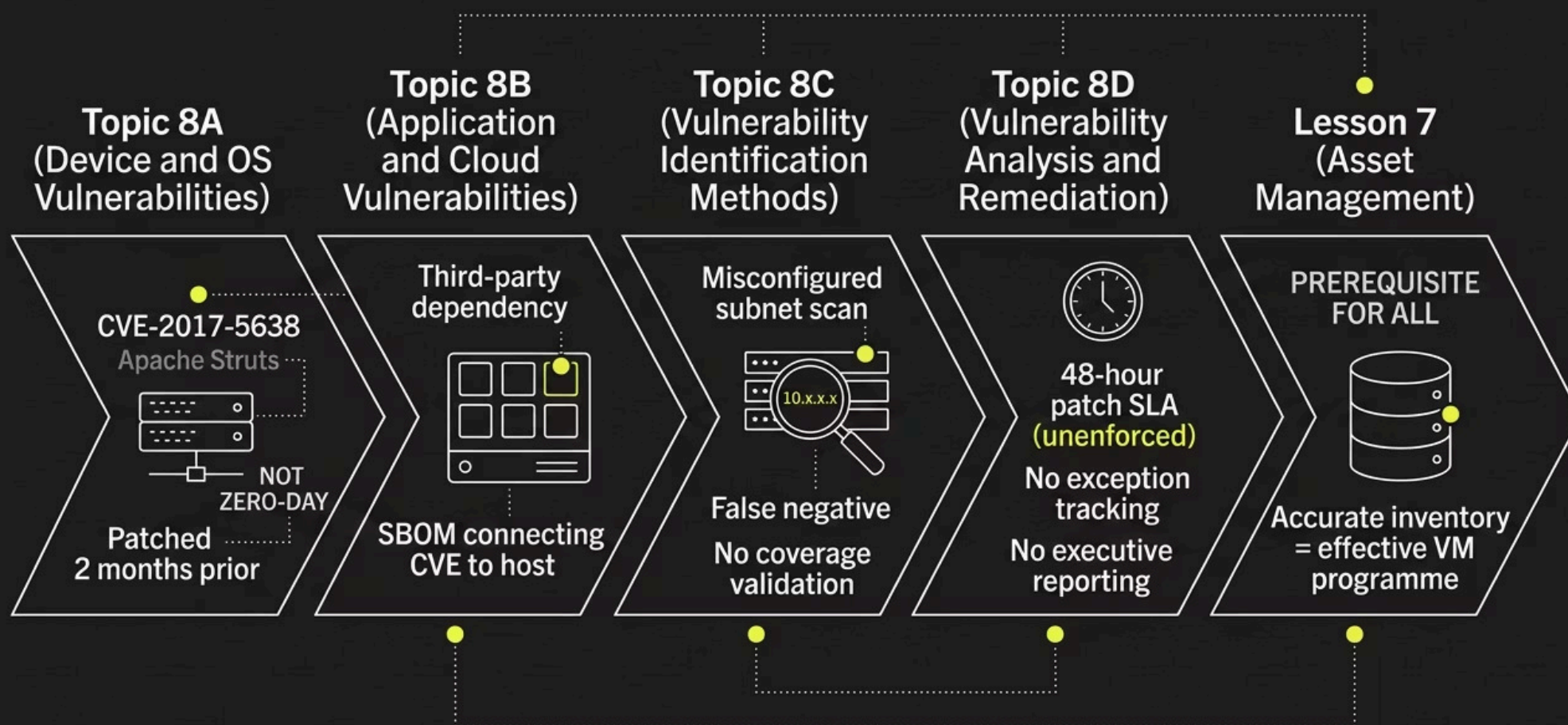
- **35% stock decline** in the weeks following disclosure
- **US\$700 million** in regulatory and class-action settlements
- **US\$1.4B–\$1.7B** total estimated cost including remediation, security investment, legal fees, and reputational damage
- FTC, CFPB, and 50 state attorneys general involved in enforcement

Australian Context

Veda (now Equifax Australia) operated on **separate infrastructure** and was not affected. Australian credit holders' data was outside the breach scope. However, the OAIC and ASIC both issued formal monitoring statements, and Australian regulators subsequently cited Equifax as a reference case in guidance on **patch management obligations** and mandatory data breach response under the Notifiable Data Breaches scheme.

Mapping Failures to Lesson 8 Topics

Every failure mode in the Equifax breach maps directly to a topic covered in Lesson 8. This is not coincidence — these controls exist precisely because attacks like this are predictable and preventable.



③ The 92% statistic from Slide 5 is directly illustrated here: CVE-2017-5638 was **not a zero-day**. It was a known, patched vulnerability exploited two months after a fix was available. The vast majority of breaches exploit known issues.

Discussion: How Do Six Failures Coexist?

Q1: Equifax had vulnerability scanners, threat intel feeds, and documented patch processes. How could six distinct failures combine within a single organisation?

The Core Insight

Vulnerability management is a workflow, not a tool. Equifax had the tools and the policy. What they did not have was the operational discipline to make those tools work together. Each tool functioned in isolation; the workflow connecting them broke at multiple points simultaneously.

What a Mature Programme Looks Like

- Asset inventory accuracy validated continuously
- Scan coverage verified against the full asset register
- Threat intel correlated against live asset data
- SLA tracking with automated escalation for overdue critical CVEs
- Exception management with documented, approved gaps
- Executive reporting on Critical CVEs outside SLA

Practitioner question to ask any client: *"Show me the workflow from CVE disclosure to patched system."* The gaps in that workflow are where the next Equifax happens.

Discussion: Building Detection That Works

Q2: The breach ran undetected for 76 days. What detection capability was absent, and how would you advise a client to build it?



TLS Inspection Hygiene

The root cause was an expired certificate on the inspection appliance — a **foundational hygiene failure**. Certificate expiry monitoring is table stakes. Inspection tools must be validated as operational, not assumed.



Behavioural & Network Detection

Large outbound transfers from a single host; new outbound destinations; traffic volume anomalies — each should trigger alerts. Network anomaly detection and NetFlow analysis would have flagged 76 days of staged exfiltration.



Data-Level Controls

DLP policies to flag sensitive data leaving the environment; database activity monitoring to alert on bulk queries returning millions of records. Neither was operational. Both are standard controls in any mature security stack.

Practitioner takeaway: Detection is inherently layered. No single control catches everything. Network, host, application, and data-level controls each intercept different parts of the kill chain. The combination is what creates resilience.

Discussion: The Pattern Across Eight Cases

Q3: How does Equifax connect to Target, Medibank, Heartbleed, Uber, Colonial, Capital One, and CrowdStrike?

Each prior case had a **known, preventable control failure** as its proximate cause:

- **Target**

HVAC vendor identity — third-party access without adequate segmentation

- **Medibank**

Reused contractor password — credential hygiene and MFA absent

- **Heartbleed / Uber / Colonial**

Untested library in production; MFA fatigue exploitation; unused VPN account without MFA

- **Capital One / CrowdStrike**

Over-permissioned IAM role; content update bypassing normal release validation

- **Equifax**

Critical CVE not patched — known for 67 days before exploitation

📌 **The unifying pattern:** The controls that should have prevented each failure were **known, established, and within reach**. The failure was **operational**, not architectural. Architecture provides design intent; operations provide reality. The spine question for any client engagement: *"Are your operational controls actually operating — or do they just exist on paper?"*

Key Takeaways for Practitioners



Asset Inventory is Non-Negotiable

Every downstream control — scanning, patching, detection — depends on knowing what you have. Validate continuously, not once.



VM is a Workflow, Not a Tool

Audit the full chain from CVE disclosure to confirmed remediation. Find the gaps between tools — that is where breaches live.



Validate Scan Coverage

A scan that misses the vulnerable host is worse than no scan — it creates false confidence. Coverage validation is mandatory.



Layer Your Detection

No single tool catches everything. Network, host, application, and data-level controls each cover different kill chain stages. Maintain all layers — and verify they are operational.

